

FUNDAÇÕES DO FORTE

CYBERSECURITY VS. INFORMATION SECURITY



4

LISTA DE FIGURAS

Figura 1 – UAC solicitando permissão para a instalação de software.....	5
Figura 2 – PDFBewerbungsmappe.exe: <i>dropper</i> do GoldenEye.....	6
Figura 3 – Pilares básicos da Segurança da Informação	9
Figura 4 – Curva de tolerância ao risco.....	11
Figura 5 – Defesa em profundidade	13
Figura 6 – Camadas da defesa em profundidade	14
Figura 7 – Conceito da simplicidade	17



SUMÁRIO

CYBERSECURITY VS. INFORMATION SECURITY	4
1 INTRODUÇÃO	4
2 PROTEGENDO A INFORMAÇÃO CONTRA AMEAÇAS.....	7
2.1 Definição de Segurança da Informação	7
3 INTRODUÇÃO AO ROSI (RETURN ON SECURITY INVESTMENT).....	9
4 PRINCÍPIOS DA SEGURANÇA DA INFORMAÇÃO	11
4.1 Privilégios mínimos (Least Privilege).....	12
4.2 Defesa em profundidade (Defense in depth)	12
4.3 Elo mais fraco.....	14
4.4 Ponto de verificação (check point)	15
4.5 Segurança por obscuridade (security by obscurity).....	15
4.6 Princípio da simplicidade (KISS – Keep It Simple, Stupid).....	16
4.7 Segregação de funções (SoD – Separation of duties)	17
CONCLUSÃO.....	18
REFERÊNCIAS.....	19

CYBERSECURITY VS. INFORMATION SECURITY

1 INTRODUÇÃO

O conceito de cibersegurança é muito amplo, mas, pode-se dizer que é relativo à preocupação com ferramentas, práticas, conceitos e políticas destinados à **proteção da informação** e à identificação e mitigação dos riscos aos quais essa informação possa vir a ser exposta – em última análise – para que seja garantida a continuidade do negócio.

Entretanto, o conceito de proteção, ou seja, de segurança dessa informação, pode não ser tão claro e intuitivo como inicialmente aparenta ser.

É procedimento comum em pequenas e, por vezes, até em médias empresas que a Segurança da Informação seja delegada a profissionais de TI (em sentido amplo), os quais não necessariamente são providos da visão e da especialização necessárias ao trabalho com a Segurança da Informação. Isso leva a resultados invariavelmente aquém do esperado, a custos geralmente mais elevados do que o planejado e quase sempre com impacto indesejado sobre o negócio.

É notório também que, quanto mais seguro for o ambiente, menos operacional – ou, como popularmente descrito, “mais engessado” – será. A Segurança da Informação envolve, entre outros aspectos, a manutenção de **privilégios mínimos**, ou seja, a garantia de que um usuário comum não tenha privilégios suficientes, por exemplo, para instalar um software, uma vez que esta é claramente uma tarefa administrativa e, portanto, restrita ao administrador do sistema.

Diante disso, no entanto, alguns profissionais com conhecimento limitado em relação à Segurança da Informação poderão afirmar que tal prática produzirá impacto negativo sobre o negócio. Ao limitar-se a execução até das tarefas mais triviais ao administrador do sistema, a produtividade do usuário final será consideravelmente prejudicada. O que levará o administrador a priorizar tarefas menores em detrimento de afazeres mais relevantes a fim de minimizar essa perda de produtividade, conduta também considerada como inadequada.

Em vista de tudo isso, os defensores de tal argumentação poderiam erroneamente concluir que, “no fundo, este problema pode ser facilmente resolvido” conferindo-se ao usuário privilégios mais elevados (talvez até irrestritos) no sistema.

Na verdade, entretanto, deve-se sempre ter em mente que não se trata simplesmente de conferir privilégios mais elevados ao usuário comum, mas sim de conscientizá-lo e impedi-lo de executar ações administrativas, ou quaisquer outras que venham a extrapolar suas reais atribuições – no caso, a instalação de um software.

Nesse contexto, tomemos como exemplo uma situação hipotética, porém muito comum: um usuário inicia a instalação de um software baixado da internet e, em dado momento do processo de instalação, ele se depara com uma mensagem do sistema, semelhante à ilustrada pela Figura “UAC solicitando permissão para instalação de software”.

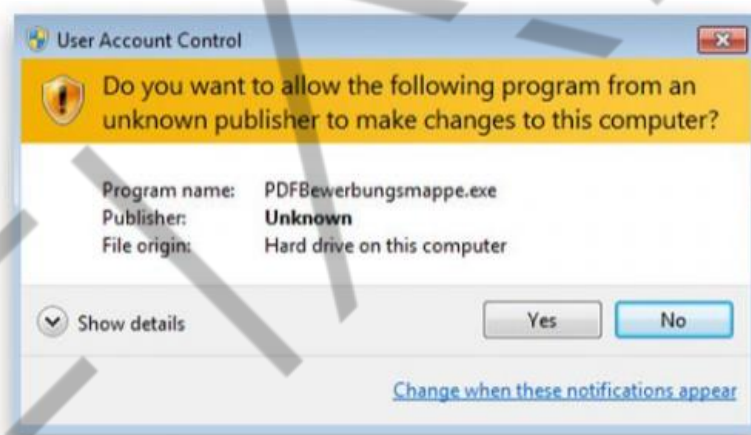


Figura 1 – UAC solicitando permissão para a instalação de software
Fonte: Malwarebytes (2017)

Um usuário comum certamente não teria condições de avaliar de maneira adequada o risco inerente à instalação de um software desconhecido em seu sistema, geralmente autorizando, em função disso, a continuidade da tarefa. O botão “Yes” seria clicado!

No caso específico do software mostrado na Figura “UAC solicitando permissão para instalação de software” (PDFBewerbungsmappe.exe), um profissional com um olhar mais aguçado em Segurança de Informação faria uma consulta a sites especializados e concluiria se tratar do GoldenEye, *dropper* (inoculador) do Petya / Mischa (Figura “PDFBewerbungsmappe.exe: *dropper* do GoldenEye”), mencionado brevemente no Capítulo 3 (“CyberSecurity começa aqui!”) desta fase.

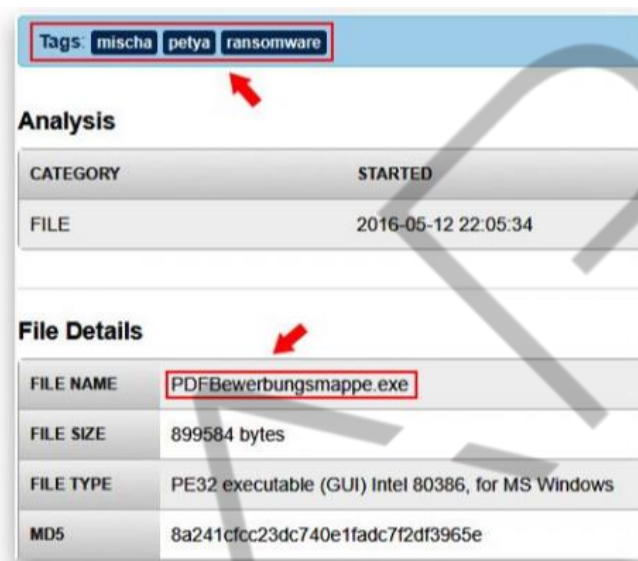


Figura 2 – PDFBewerbungsmappe.exe: *dropper* do GoldenEye
Fonte: Malwr (2017)

Portanto, pode-se afirmar que o uso seguro de um sistema ou de uma rede computacional exige, também, a clara definição dos **papéis e responsabilidades** de seus usuários, em todos os níveis de utilização, e não apenas nos mais altos.

Atividades administrativas em geral não devem, ao menos em princípio, ser permitidas a usuários comuns, pois exigem privilégios elevados. E a concessão de tais privilégios a quem não tem condições de avaliar de maneira adequada como utilizá-los de forma segura certamente produzirá resultados muito diferentes dos esperados.

2 PROTEGENDO A INFORMAÇÃO CONTRA AMEAÇAS

2.1 Definição de Segurança da Informação

É bem comum a equivocada ideia de que a Segurança da Informação se resume a equipamentos e tecnologias, como, por exemplo, *firewalls*, IPSs e proxies, entre outros. E, é claro, falaremos mais sobre eles adiante. Contudo, Segurança da Informação vai muito além disso.

“If you think **technology** can solve your **security problems**, then you don’t understand the problems and you don’t understand the technology.”

BRUCE SCHNEIER

Entretanto, de acordo com Bruce Schneier, renomado criptógrafo, especialista em Segurança da Informação e autor de várias obras nesse segmento, se você pensa que a tecnologia pode resolver seus problemas de segurança, é porque, na verdade, você não entende nem os problemas nem a tecnologia.

Segundo Nakamura e Geus (2002, p. 9, grifos nossos), “[...] a informação é um **ativo que, como qualquer outro ativo importante, é essencial para os negócios de uma organização** e, conseqüentemente, necessita ser adequadamente protegida”.

Não obstante, é notório ainda que a informação pode existir sob diversas formas, como, por exemplo, impressa ou escrita em papel, armazenada eletronicamente e falada.

Segundo a norma NBR ISO/IEC 27002 (2005, apud Dantas, 2011, p.11), “É a proteção da informação quanto a vários tipos de ameaças, de modo a garantir a continuidade do negócio, minimizar o risco para o negócio, maximizar o retorno sobre o investimento e as oportunidades de negócios”.

A ABNT (2006, grifos nossos) menciona que a segurança da informação é caracterizada pela preservação da **disponibilidade, integridade** e

confidencialidade da informação, além de outras propriedades como autenticidade, confiabilidade, não-repúdio e responsabilidade sobre a informação.

Confidencialidade da informação significa que esta deverá ser revelada, ou estar acessível, unicamente aos que tiverem autorização para isso.

A **integridade é a propriedade que garante a exatidão e a plenitude da informação**, o que não significa que esta não possa sofrer alterações ao longo de seu ciclo de vida, mas sim que tais alterações devem ser legítimas.

A **disponibilidade é a propriedade da informação de estar disponível e acessível, quando necessário**, aos que tiverem a devida autorização para isso.

Essa tríade representa os pilares básicos da Segurança da Informação, sendo referenciada, em geral, simplesmente como **CID** (Figura “Pilares básicos da Segurança da Informação”).

É recorrente em ambientes com baixa maturidade corporativa, carentes de processos e controles adequados, e repletos de interpretações inadequadas da CID.

Considere-se, a título de exemplo, um servidor em que o serviço de compartilhamento de arquivos (ou qualquer outro) seja mantido em produção em período integral (24 x 7), independentemente de ser, ou não, requisitado por seus usuários.

A princípio, talvez alguns possam acreditar ser esse o conceito de disponibilidade, entretanto, observando-se o disposto pela ABNT (2016), conclui-se que, na verdade, a disponibilidade de qualquer serviço só é computada (e justificável) durante o período em que seus usuários legítimos o requisitarem em conformidade com as Políticas de Segurança da Informação (PSI) da organização.

Desse modo, a Segurança da Informação será maior se os serviços forem mantidos em produção de forma adequada, evitando que sejam desnecessariamente expostos (mesmo que somente na rede local). O que pode ser efetivado, por exemplo, por intermédio de *scripts* que automatizem a inicialização e a parada seletiva de cada serviço, em conformidade com as PSI.



Figura 3 – Pilares básicos da Segurança da Informação
Fonte: Adaptado por Fiap (2020)

A **autenticidade** tem como objetivo determinar a validade da transmissão, da mensagem e de seu remetente, a fim de permitir ao destinatário comprovar a origem e a autoria de um documento; enquanto o **não repúdio** tem como objetivo garantir que o autor não possa negar a criação e a assinatura do documento.

Tais propriedades vêm se tornando cada vez mais relevantes e evidentes, sendo implementadas por intermédio de técnicas de certificação e assinatura digitais, e de protocolação eletrônica de documentos.

De maneira simplificada, o certificado digital é a identidade digital da pessoa física ou jurídica no meio eletrônico, tendo como função garantir a **autenticidade**, **confidencialidade**, **integridade** e **não repúdio** das operações realizadas por seu intermédio. Assegura também a validade jurídica e permite que diversos serviços sejam realizados sem a necessidade da presença física – dessa forma, agilizando processos e reduzindo custos.

3 INTRODUÇÃO AO ROSI (RETURN ON SECURITY INVESTMENT)

O conceito de Retorno sobre o Investimento (ROI) aplica-se a todos os investimentos, não sendo exceção a Segurança da Informação.

De acordo com o programa de trabalho da ENISA em 2012, a fim de estimarem quanto deverá ser investido em segurança, os executivos precisam saber quanto a falta dela poderá custar ao negócio, e quais soluções mostram-se mais economicamente viáveis e satisfatórias.

Nesse contexto, tem-se o **ROSI (Retorno sobre o Investimento em Segurança da Informação)**, cujo cálculo poderá responder a questões financeiras essenciais, como: **A organização está pagando excessivamente por segurança? Quanto a falta de segurança poderá impactar (financeiramente) a produtividade? Quando os investimentos em segurança são suficientes? Essa prática ou esse dispositivo de segurança traz, efetivamente, benefícios?**

Entretanto, há que se ressaltar que a abordagem financeira tradicional aplicável ao cálculo do ROI não é apropriada para avaliar iniciativas relacionadas à Segurança da Informação, uma vez que **investimentos realizados em Segurança da Informação geralmente não têm como resultado ou objetivo a obtenção de lucro, estando mais relacionados à prevenção de perdas.**

É por essa razão que a importância de tais investimentos, por vezes, não é percebida e devidamente mensurada. Investimentos em Segurança da Informação são como investir em boas rodas e pastilhas de freio para um automóvel: em condições normais, as vantagens são imperceptíveis, mas, no caso de um incidente, sua ausência certamente será percebida.

Em outras palavras, é esperado que os investimentos direcionados à Segurança da Informação minimizem os riscos aos quais os ativos da organização possam vir a ser expostos, e não a obtenção de benefícios – particularmente financeiros; ou seja, nesses termos, a avaliação quantitativa do ROSI dá-se calculando quanto de perda para o negócio tais investimentos poderão evitar.

A Figura “Curva de tolerância ao risco” representa a curva característica (genérica) de mitigação dos riscos relacionados à Segurança da Informação em razão dos investimentos recebidos.

Com base no perfil dessa curva, é possível observar que investimentos reduzidos em Segurança da Informação agravam consideravelmente o risco, podendo também potencializar o impacto sobre o negócio produzido por eventuais incidentes de segurança.

É importante salientar ainda que esse impacto, normalmente, vai além das perdas financeiras diretas, ocasionando também desgaste da imagem corporativa e da reputação da empresa.

Já no outro extremo da curva, é possível observar que, a partir de determinado ponto, os riscos não poderão mais ser mitigados, independentemente dos investimentos realizados em Segurança da Informação. Isso torna evidente a necessidade de determinação do ponto de equilíbrio entre risco e investimento (em Segurança da Informação), tendo-se como referência as necessidades e os objetivos de negócio.

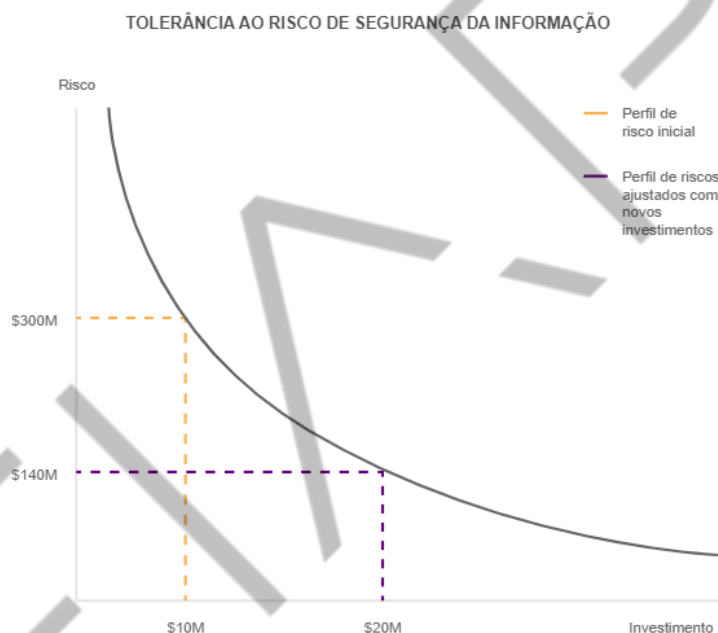


Figura 4 – Curva de tolerância ao risco
Fonte: Elaborado pelo autor (2017)

4 PRINCÍPIOS DA SEGURANÇA DA INFORMAÇÃO

Diferentes técnicas e princípios deverão ser combinados para compor soluções adequadas e abrangentes, capazes de mitigar riscos e reforçar a Segurança da Informação.

O Sistema de Administração dos Recursos de Tecnologia da Informação (SISP), do Poder Executivo Federal, entre outras reconhecidas instituições, coloca como estratégias fundamentais para a proteção da Segurança da Informação:

4.1 Privilégios mínimos (Least Privilege)

Os usuários deverão ter seus privilégios para uso dos recursos informáticos limitados ao mínimo necessário para o pleno desempenho de suas funções, evitando, dessa maneira, a desnecessária exposição a riscos, como, por exemplo, a instalação de códigos maliciosos, conforme anteriormente discutido.

O US-CERT acrescenta ainda que a concessão de privilégios excessivos a um usuário pode permitir que ele venha a obter ou alterar informações de maneira indesejada, mesmo que de maneira involuntária. Logo, a cuidadosa delegação de privilégios poderá contribuir expressivamente para impedir que condutas impróprias ou inadequadas venham a comprometer algum dos pilares da Segurança da Informação e, ainda, para a redução dos riscos para o negócio.

4.2 Defesa em profundidade (Defense in depth)

A defesa em profundidade pode ser entendida como a implementação de um sistema defensivo **na forma de camadas**, no qual diferentes mecanismos de proteção se complementam, ampliando a abrangência e a efetividade desse sistema como um todo.

Tome-se como exemplo de defesa em profundidade a topologia ilustrada na Figura “Defesa em profundidade”, em que um UTM é empregado para a proteção da borda entre a rede confiável (LAN) e a rede não confiável (internet).

Apesar de ele ser capaz de inspecionar e disciplinar adequadamente o tráfego entre as duas redes, não é capaz de detectar ou proteger os *hosts* da rede local contra um ataque interno, como, por exemplo, um ataque de força bruta desferido por um usuário mal-intencionado contra um servidor interno.

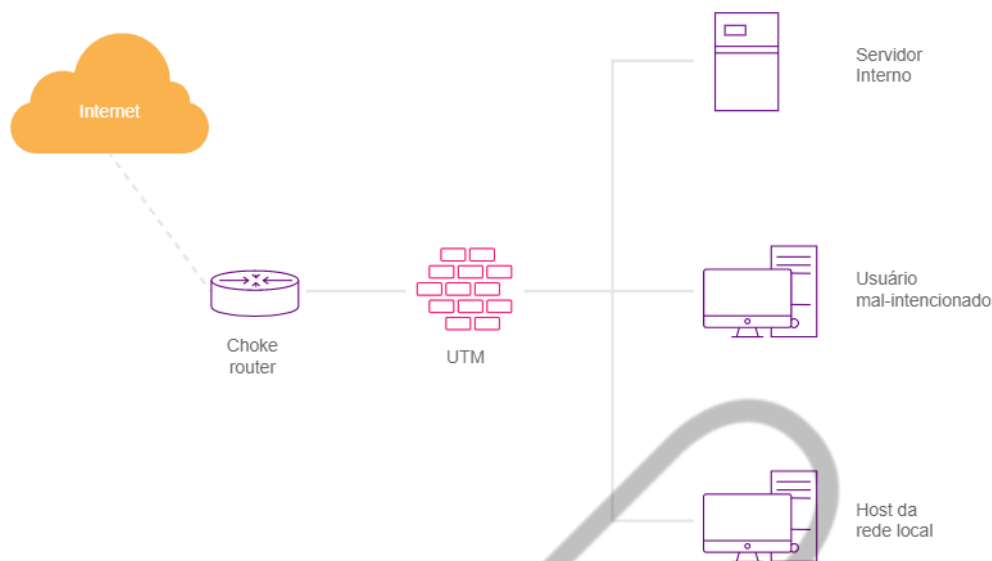


Figura 5 – Defesa em profundidade
Fonte: Elaborado pelo autor (2017)

Talvez você tenha pensado que proteger a infraestrutura de ataques internos é uma medida desnecessária; é muito mais intuitivo pensar que os atacantes mal-intencionados são externos e estão na internet organizados em grupos extremistas. Pois saiba que o número de ataques oriundos de *hosts* internos é grande e está crescendo: o estudo “The Ponemon Institute 2018 Cost of Insider Threats” indica que os incidentes gerados em razão de um colaborador desavisado – que comete um erro humano – ou de um descontente com a empresa – que deseja realmente provocar dano – têm um custo médio de US\$ 513 mil, podendo causar à empresa prejuízos de US\$ 8,76 milhões ao ano (EKARAN, 2019). É importante ressaltar que esses números talvez sejam subestimados: a maioria dos ataques internos não é reportada, afinal, trata-se de má publicidade.

Ainda na Figura “Defesa em profundidade”, é possível observar que o UTM constitui a segunda linha de defesa do perímetro, sendo a primeira consistida pelo **choke router**, que tem como função promover a filtragem inicial dos pacotes que entram e/ou saem da rede. O UTM complementa com uma inspeção mais profunda que amplia a superfície de proteção geral do sistema, implementando mecanismos de defesa adicionais, como sistemas de prevenção de intrusão (IPS) e filtragem de conteúdo, entre outros.

A Figura “Camadas da defesa em profundidade” representa o modelo conceitual da defesa em profundidade e suas camadas.



Figura 6 – Camadas da defesa em profundidade
Fonte: ISSA Brasil – CNASI (2013)

4.3 Elo mais fraco

Os profissionais de Segurança da Informação geralmente a consideram como um encadeamento de estratégias e, por isso, tão forte quanto seu elo mais fraco. Uma vez que atacantes certamente procurarão identificar e explorar os pontos mais vulneráveis dos sistemas de proteção, a fim de superá-los.

Tomando novamente como referência a topologia representada na Figura “Defesa em profundidade”, considere-se agora que o servidor interno deva ser acessado com segurança também a partir da rede não confiável (internet).

Entre outras soluções possíveis, uma das mais simples e econômicas recai sobre a implementação de uma VPN, que é também uma funcionalidade do próprio UTM, com mecanismos de autenticação adequados, como, por exemplo, o uso de credencial forte, na qual nem o nome de usuário nem a respectiva senha sejam de fácil dedução.

Aliando-se a uma credencial forte mecanismos de defesa complementares, como, por exemplo, o bloqueio da credencial utilizada após um determinado número de tentativas de acesso malsucedido, é mais provável que, para a obtenção das credenciais do usuário, um atacante venha a recorrer a técnicas de Engenharia Social, ao invés de ataques diretos ao serviço (por exemplo, dicionário ou força bruta).

4.4 Ponto de verificação (check point)

Observando-se a topologia representada pela Figura “Defesa em profundidade”, percebe-se que o conjunto <*choke-router* + UTM> constitui o único ponto para a troca de tráfego entre a rede confiável (LAN) e a rede não confiável (internet).

Desse modo, tal conjunto configura o chamado ponto de verificação (*check point*), por intermédio do qual **todo o tráfego** que adentra ou deixa a rede confiável (LAN), poderá ser adequadamente inspecionado e submetido às políticas de segurança configuradas, minimizando a possibilidade de comprometimento de algum dos pilares da Segurança da Informação.

4.5 Segurança por obscuridade (security by obscurity)

A segurança por obscuridade remete à dependência do segredo do projeto ou implementação, como forma de garantir sua segurança.

Simplificadamente, isso significa que, mesmo que um sistema, ou um de seus componentes, apresente vulnerabilidades, sua segurança ainda poderá ser (supostamente) mantida, enquanto tais vulnerabilidades não se tornarem conhecidas por terceiros.

O OWASP avalia que a defesa por obscuridade é um controle de segurança frágil, e que, na maior parte das vezes, falha quando é o único controle. Não devido ao fato de que manter segredos seja uma má ideia, mas porque a segurança de um sistema importante não deve depender da ocultação de seus detalhes; por exemplo, a segurança de um aplicativo não deve recair sobre o segredo de seu código-fonte.

Haja vista o sistema operacional Linux que, via de regra, é um *software livre* cujo **código-fonte é aberto** e amplamente disponibilizado, entretanto, quando configurado de maneira adequada, é um dos sistemas operacionais mais seguros e robustos disponíveis no mercado. Sua segurança reside no fato de que, se por um lado, vários indivíduos maliciosos terão acesso às fraquezas do software e saberão como explorá-las, por outro, uma quantidade equivalente de profissionais bem-

intencionados terá acesso às mesmas fraquezas e alertará os desenvolvedores, que as corrigirão, ou ainda, eles mesmos o farão. Viva o código-fonte aberto!

4.6 Princípio da simplicidade (KISS – Keep It Simple, Stupid)

O princípio da simplicidade é, por vezes, também referenciado como o “princípio do beijo” (KISS). Ainda segundo o OWASP, a superfície de ataque e a simplicidade são intimamente relacionadas, acrescentando ainda que certas práticas da engenharia de software privilegiam abordagens excessivamente complexas, em detrimento do que poderia ser um código relativamente mais simples e direto.

O problema decorre do fato de que a complexidade de um código dificulta seu pleno entendimento e, portanto, ao longo do processo de desenvolvimento, isso poderá vir a torná-lo vulnerável.

Considere, por exemplo, o *script* de um *firewall* (UTM) composto por centenas de linhas. E que um administrador ainda pouco familiarizado com esse *script* tenha de adicionar regras específicas que permitam a uma nova aplicação entrar em produção o mais rapidamente possível.

Considerando-se a complexidade do *script* (também em decorrência de sua extensão), associada ao tempo insuficiente para seu pleno entendimento, é provável que esse administrador comece a inserir e testar novas regras sem o devido critério, até obter o resultado desejado; comportamento que, embora inicialmente aparente ter resolvido a demanda de maneira adequada, pode, na verdade, estar criando vulnerabilidades que impactarão os mecanismos de defesa implementados por esse *firewall* (UTM).

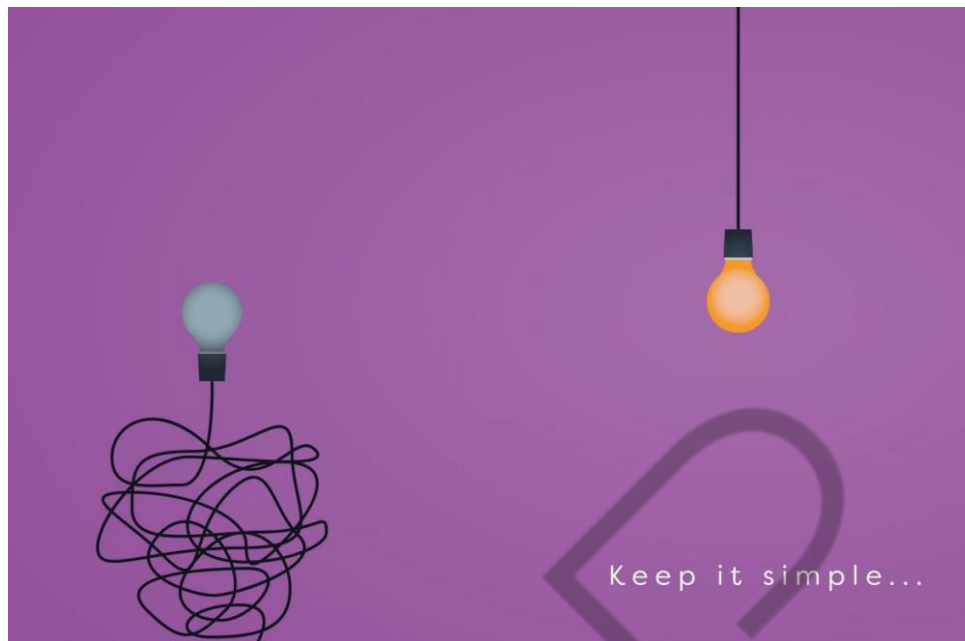


Figura 7 – Conceito da simplicidade
Fonte: Google Imagens (2017)

4.7 Segregação de funções (SoD – Separation of duties)

A SoD é um controle clássico para a resolução de conflitos de interesse e prevenção a fraudes, basicamente, mediante a restrição dos poderes de cada indivíduo e a criação de barreiras, fazendo com que mais de uma pessoa seja necessária para a conclusão de uma tarefa.

O COBIT4.1 recomenda, no item PO4.11 Segregação de Funções:

Implementar uma **separação de papéis e responsabilidades** que reduza a possibilidade de um único indivíduo subverter um processo crítico. A gerência também deve se certificar de que o pessoal esteja executando apenas tarefas autorizadas relevantes aos seus respectivos cargos e posições.

Não obstante, também a ISO/IEC 27001:2005 recomenda a segregação de funções (objetivo de controle A.10.1.3), a fim de garantir a operação correta e segura de instalações para o processamento da informação. E como forma de reduzir o risco de acessos não autorizados a um ativo ou, ainda, alguma modificação ou mau uso não intencional.

O OWASP cita, como exemplo, que um administrador deve ser capaz de inicializar e desligar um sistema, ou de implementar uma política de senhas; mas não deve ser capaz de fazer *login* no sistema como um usuário superprivilegiado e executar ações em nome de outros usuários.

Além dos princípios citados, o OWASP oferece ainda outras recomendações, como, por exemplo, a **Redução da Superfície de Ataques**, o que significa que cada funcionalidade adicionada a uma aplicação acrescenta também certo risco à aplicação como um todo; por exemplo, considere que uma determinada aplicação *web* implemente um *help online* com função de busca, essa função poderá ser vulnerável a ataques de SQL Injection.

CONCLUSÃO

Como vimos ao longo do capítulo, a Segurança da Informação vai muito além de equipamentos e tecnologia: **um conjunto de princípios deve guiar as estratégias corretas** e, por sua vez, a tecnologia deverá dar suporte a tais estratégias. Além disso, Segurança da Informação não se restringe ao Departamento de TI da empresa, ela deve ser um princípio organizacional e uma responsabilidade de todos.

REFERÊNCIAS

ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27001 Tecnologia da informação - Técnicas de segurança - Requisitos. Rio de Janeiro, 2006.

BRASIL. Tribunal de Contas da União. **Boas práticas em segurança da informação**. 4^a ed. 2014. Disponível em: <<http://www4.planalto.gov.br/cgd/assuntos/publicacoes/2511466.pdf>>. Acesso em: 11 dez. 2020.

CERTSIGN. **O que é certificado digital?** Disponível em: <<https://www.certisign.com.br/certificado-digital/o-que-e-certificado-digital>>. Acesso em: 11 dez. 2020.

DANTAS, Marcus Leal. **Segurança da Informação**: uma abordagem focada em gestão de Riscos. Olinda, 2011.

ENISA – EUROPEAN UNION AGENCY FOR NETWORK AND INFORMATION SECURITY. **Introduction to return on security investment – helping CERTs assessing the cost of (lack of) security**. 2012. Disponível em: <https://www.enisa.europa.eu/publications/introduction-to-return-on-security-investment/at_download/fullReport>. Acesso em: 11 dez. 2020.

FERNANDES, J. H. C. **Gestão da segurança da informação e comunicações**. 2010. Disponível em: <https://dsic.planalto.gov.br/legislacao/3_Livro_GSIC_UNB.pdf/@@download/file/3_Livro_GSIC_UNB.pdf>. Acesso em: 11 dez. 2020.

INSIDER threat statistics for 2019: facts and figures. **Ekrans**, 2019. Disponível em: <<https://www.ekransystem.com/en/blog/insider-threat-statistics-facts-and-figures>>. Acesso em: 11 dez. 2020.

MAGNUSSON, C.; MOLVIDSSON, J.; ZETTERQVIST, S. **Value creation and Return On Security Investments (ROSI)**. Disponível em: <https://link.springer.com/content/pdf/10.1007%2F978-0-387-72367-9_3.pdf>. Acesso em: 11 dez. 2020.

MCGUINNESS, T. **Defense in depth**. 2001. Disponível em: <<https://www.sans.org/reading-room/whitepapers/basics/defense-in-depth-525>>. Acesso em: 11 dez. 2020.

MSKRUEGER, T. **Segurança de informação**. 2013. Disponível em: <<http://www.egov.ufsc.br/portal/conteudo/seguranca-de-informacao>>. Acesso em: 11 dez. 2020.

NAKAMURA, E.; GEUS, P. **Segurança de redes em ambientes corporativos**. São Paulo: Berkeley Brasil, 2002.

OWASP. **Security by design principles**. 2016. Disponível em: <https://www.owasp.org/index.php/Security_by_Design_Principles>. Acesso em: 11 dez. 2020.

SISP - Segurança da informação e comunicações. **Governo Digital**, [s.d.] Disponível em: <<https://www.gov.br/governodigital/pt-br/sisp>>. Acesso em: 11 dez. 2020.

TJAL. **Segurança de informação**. Disponível em: <http://www4.tjal.jus.br/WebHelp/id_seguranca_da_informacao.htm>. Acesso em: 8 out. 2019.

EMANIP